

Adaptive Web Vulnerability Scan Report

Target: https://www.cbse.gov.in/cbsenew/cbse.html

Scan ID: c254c7ae-ee29-49e1-bdbb-d8d7a09b0253

Pages 1	Forms 3	Endpoints 9	Findings 11	API endpoints 6
GraphQL endpoints 2	Average anomaly 0	Passive score 40	High-risk endpoints 8	Schema fuzz probes 6
Open ports 5	Authenticated context No			

Scan Profile

Profile Bounty Standard	Detectors sqli, xss, csrf, auth_bypass, advanced_surface, advanced_injection, advanced_client, advanced_auth, advanced_server	API fuzzing Enabled	GraphQL checks Enabled	Rate limit / sec 2.0
----------------------------	--	------------------------	---------------------------	-------------------------

Severity split: High 3, Medium 8, Low 0

Recon Intelligence

WAF Not detected	TLS TLSv1.3	Screenshot failed	Missing headers 5
---------------------	----------------	----------------------	----------------------

Technologies: none

Open ports: 80 http 443 https 8000 dev-http 8080 proxy-or-dev-http 8443 alt-https

Endpoint Risk Ranking

Risk	Method	Source	URL	Reasons
70	GET	directory-fuzzing	https://www.cbse.gov.in/openapi.json	openapi keyword, api keyword, directory-fuzzing source
65	post	common-probe	https://www.cbse.gov.in/rest/user/login	login keyword, rest keyword, user keyword
60	post	common-probe	https://www.cbse.gov.in/api/graphql	graphql keyword, api keyword
55	get	common-probe	https://www.cbse.gov.in/rest/products/search?q=apple	rest keyword, search keyword, parameterized
55	GET	directory-fuzzing	https://www.cbse.gov.in/admin	admin keyword, directory-fuzzing source

Risk	Method	Source	URL	Reasons
55	GET	directory-fuzzing	https://www.cbse.gov.in/debug	debug keyword, directory-fuzzing source
55	GET	directory-fuzzing	https://www.cbse.gov.in/swagger	swagger keyword, directory-fuzzing source
55	GET	directory-fuzzing	https://www.cbse.gov.in/swagger.json	swagger keyword, directory-fuzzing source
45	post	common-probe	https://www.cbse.gov.in/graphql	graphql keyword
45	GET	directory-fuzzing	https://www.cbse.gov.in/login	login keyword, directory-fuzzing source
45	GET	directory-fuzzing	https://www.cbse.gov.in/upload	upload keyword, directory-fuzzing source
25	get	common-probe	https://www.cbse.gov.in/api	api keyword
25	get	common-probe	https://www.cbse.gov.in/rest	rest keyword
25	get	common-probe	https://www.cbse.gov.in/api/Products	api keyword
25	get	common-probe	https://www.cbse.gov.in/rest/products	rest keyword
10	get	crawler	https://www.cbse.gov.in/cbsenew/cbse.html	standard surface

Scan Timeline

Progress	Phase	Message	Timestamp
5%	startup	Target reachable and scan initialized	2026-06-04T17:32:59.474290+00:00
30%	crawl	Mapped 1 pages, 3 forms, and 9 endpoints	2026-06-04T17:33:16.086539+00:00
88%	validation	Validated 11 candidate findings	2026-06-04T17:35:03.228401+00:00
92%	recon	Passive recon, endpoint risk, TLS, and low-impact discovery completed	2026-06-04T17:35:16.641574+00:00

Detector Registry

sqli injection query / form / api Tests query parameters, forms, and API-like inputs for error-based, boolean-based, and time-delay SQL injection signals.	xss client-side query / form / api / dom Checks reflected, DOM-rendered, and persistence-oriented XSS indicators across common input surfaces.	csrf workflow form Flags state-changing forms and endpoints that appear to lack anti-CSRF protections.	auth_bypass authorization page / api Looks for privileged or admin-style resources that are reachable without expected access controls.	advanced_surface attack-surface api / graphql / spa / auth / websocket / file-upload Safely flags GraphQL, OpenAPI, admin, upload, auth, and WebSocket surfaces for advanced validation workflows.
advanced_injection injection nosql / command / ldap / xpath / ssti / xxe / deserialization Heuristically identifies NoSQL, command, LDAP, XPath, SSTI,	advanced_client client-side dom-xss / stored-xss / blind-xss / prototype-pollution / dom-clobbering Flags DOM XSS, stored/blind XSS, prototype pollution,	advanced_auth auth jwt / oauth / mfa / session / idor / bola / rbac Flags JWT, OAuth/OIDC, MFA/session, IDOR, BOLA, and RBAC	advanced_server server-side ssrf / file-upload / path-traversal / cache-poisoning / host-header / websocket / race / request-smuggling Flags SSRF, file upload, traversal,	

XXE, and
deserialization
validation candidates.

and DOM clobbering
candidate surfaces.

bypass validation
candidates.

cache poisoning, host
header, WebSocket,
race, and request
smuggling candidates.

API Surface

API endpoints
6

GraphQL endpoints
2

Parameterized endpoints
1

Methods
GET, POST

Discovery sources: common-probe, crawler

Enterprise Intelligence

Assets
10

High-risk assets
3

Validation proof
0.3

AI high exploitability
3

Mapped compliance
11

Endpoint drift
Detected

New endpoints: <https://www.cbse.gov.in/api>, <https://www.cbse.gov.in/api/Products>, <https://www.cbse.gov.in/api/graphql>,
<https://www.cbse.gov.in/cbsenew/cbse.html>, <https://www.cbse.gov.in/graphql>, <https://www.cbse.gov.in/rest>,
<https://www.cbse.gov.in/rest/products>, <https://www.cbse.gov.in/rest/products/search?q=apple>, <https://www.cbse.gov.in/rest/user/login>

Validation engines: response-diff, timing-analysis, anomaly-analysis, safe-replay

Compliance frameworks: [OWASP ASVS](#) [OWASP Top 10](#) [PCI DSS 4.0](#) [ISO 27001](#) [NIST CSF](#)

Web Recon Intelligence

Favicon SHA
none

Robots disallow
0

Sitemap URLs
0

Source maps
0

Sensitive robots paths: none

MX records: none

NS records: none

Schema-Aware Fuzzing

Method	URL	Fields	Status	Reflected Fields
GET	https://www.cbse.gov.in/api		skipped	-
GET	https://www.cbse.gov.in/rest		skipped	-
GET	https://www.cbse.gov.in/api/Products		skipped	-
GET	https://www.cbse.gov.in/rest/products		skipped	-
GET	https://www.cbse.gov.in/rest/products/search?q=apple	q	skipped	-

GraphQL URL	Fields	Status	Data Keys	Errors
https://www.cbse.gov.in/graphql		skipped	-	0

Detector Timings

Detector	Elapsed (ms)	Findings
sqli	89024.48	0
xss	15202.32	0
csrf	0.12	3
auth_bypass	490.02	0
advanced_surface	0.11	2
advanced_injection	0.13	2
advanced_client	0.09	0
advanced_auth	0.09	2
advanced_server	0.13	2

Findings

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** https://www.cbse.gov.in/rest/user/login
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST https://www.cbse.gov.in/rest/user/login with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status - -> -, length - -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** https://www.cbse.gov.in/graphql
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST https://www.cbse.gov.in/graphql with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status - -> -, length - -> -

- **Remediation:** Add per-request CSRF tokens and validate them server-side.

CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** `https://www.cbse.gov.in/api/graphql`
- **Method:** `post`
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** `POST https://www.cbse.gov.in/api/graphql with parameter - using payload -`
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

ADVANCED_SURFACE | MEDIUM | CVSS 6.1

GraphQL endpoint requires schema and authorization review

- **URL:** `https://www.cbse.gov.in/graphql`
- **Method:** `get`
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** Passive attack surface heuristic
- **OWASP Category:** Unknown
- **Request PoC:** `GET https://www.cbse.gov.in/graphql with parameter - using payload -`
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Validate authorization, input handling, rate limits, and monitoring for this exposed surface.

ADVANCED_SURFACE | MEDIUM | CVSS 6.1

GraphQL endpoint requires schema and authorization review

- **URL:** `https://www.cbse.gov.in/api/graphql`
- **Method:** `get`
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** Passive attack surface heuristic
- **OWASP Category:** Unknown
- **Request PoC:** `GET https://www.cbse.gov.in/api/graphql with parameter - using payload -`
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Validate authorization, input handling, rate limits, and monitoring for this exposed surface.

ADVANCED_INJECTION | HIGH | CVSS 8.7

NoSQL injection candidate parameter requires operator injection validation

- **URL:** `https://www.cbse.gov.in/graphql`
- **Method:** `get`
- **Parameter:** -
- **Confidence:** medium (-)

- **Priority:** P1
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** Parameter and endpoint naming heuristic
- **OWASP Category:** Unknown
- **Request PoC:** GET https://www.cbse.gov.in/graphql with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Use strict input allowlists, parameterized APIs, parser hardening, and targeted regression tests for this sink.

ADVANCED_INJECTION | HIGH | CVSS 8.7

NoSQL injection candidate parameter requires operator injection validation

- **URL:** https://www.cbse.gov.in/api/graphql
- **Method:** get
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P1
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** Parameter and endpoint naming heuristic
- **OWASP Category:** Unknown
- **Request PoC:** GET https://www.cbse.gov.in/api/graphql with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Use strict input allowlists, parameterized APIs, parser hardening, and targeted regression tests for this sink.

ADVANCED_AUTH | MEDIUM | CVSS 6.1

Login flow requires MFA, brute-force, session fixation, and CSRF validation

- **URL:** https://www.cbse.gov.in/rest/user/login
- **Method:** get
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** Authenticated workflow heuristic
- **OWASP Category:** Unknown
- **Request PoC:** GET https://www.cbse.gov.in/rest/user/login with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Enforce server-side authorization, strong session lifecycle controls, MFA policy, and role-based regression tests.

ADVANCED_AUTH | HIGH | CVSS 8.7

IDOR/BOLA candidate requires role-differential authorization validation

- **URL:** https://www.cbse.gov.in/rest/user/login
- **Method:** get
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P1
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** Authenticated workflow heuristic
- **OWASP Category:** Unknown
- **Request PoC:** GET https://www.cbse.gov.in/rest/user/login with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Enforce server-side authorization, strong session lifecycle controls, MFA policy, and role-based regression tests.

ADVANCED_SERVER | MEDIUM | CVSS 6.1

WebSocket/GraphQL transport requires auth, origin, and message validation

- **URL:** https://www.cbse.gov.in/graphql
- **Method:** get
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** Server-side attack surface heuristic
- **OWASP Category:** Unknown
- **Request PoC:** GET https://www.cbse.gov.in/graphql with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status - -> -, length - -> -
- **Remediation:** Validate this server-side surface with scoped safe replay, strict allowlists, canonicalization, and monitoring.

ADVANCED_SERVER | MEDIUM | CVSS 6.1

WebSocket/GraphQL transport requires auth, origin, and message validation

- **URL:** https://www.cbse.gov.in/api/graphql
- **Method:** get
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** Server-side attack surface heuristic
- **OWASP Category:** Unknown
- **Request PoC:** GET https://www.cbse.gov.in/api/graphql with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status - -> -, length - -> -
- **Remediation:** Validate this server-side surface with scoped safe replay, strict allowlists, canonicalization, and monitoring.

Raw Findings Table

Detector	Severity	CVSS	Priority	Confidence	Signals	Method	Parameter	URL
csrf	medium	6.1	P2	medium (-)	-	post	-	https://www.cbse.gov.in/rest/user/login
csrf	medium	6.1	P2	medium (-)	-	post	-	https://www.cbse.gov.in/graphql
csrf	medium	6.1	P2	medium (-)	-	post	-	https://www.cbse.gov.in/api/graphql
advanced_surface	medium	6.1	P2	medium (-)	-	get	-	https://www.cbse.gov.in/graphql

Detector	Severity	CVSS	Priority	Confidence	Signals	Method	Parameter	URL
advanced_surface	medium	6.1	P2	medium (-)	-	get	-	https://www.cbse.gov.in/api/graphql
advanced_injection	high	8.7	P1	medium (-)	-	get	-	https://www.cbse.gov.in/graphql
advanced_injection	high	8.7	P1	medium (-)	-	get	-	https://www.cbse.gov.in/api/graphql
advanced_auth	medium	6.1	P2	medium (-)	-	get	-	https://www.cbse.gov.in/rest/user/login
advanced_auth	high	8.7	P1	medium (-)	-	get	-	https://www.cbse.gov.in/rest/user/login
advanced_server	medium	6.1	P2	medium (-)	-	get	-	https://www.cbse.gov.in/graphql
advanced_server	medium	6.1	P2	medium (-)	-	get	-	https://www.cbse.gov.in/api/graphql